



## CLOUD SECURITY ARCHITECTURE REPORT

## ระบบทายผลกีฬา

## Cloud Sports Prediction &amp; Betting Platform

## Secure 3-Tier Web Application on AWS

เอกสารการออกแบบสถาปัตยกรรมคลาวด์ ความปลอดภัย และโครงสร้างระบบเครือข่าย

การวิเคราะห์หลักการแนวคิด · การดำเนินการตามแนวคิด · ตาราง Routing Table · Security Groups Matrix

รายวิชา: .....

รหัสวิชา: .....

อาจารย์ผู้สอน: .....

ภาคการศึกษา / ปี: .....

คณะ / สาขาวิชา: .....

วันที่ส่งรายงาน: .....

 รายชื่อสมาชิกกลุ่ม (Group Members)

GROUP 2

| ลำดับ | ชื่อ - นามสกุล         | รหัสนักศึกษา           |
|-------|------------------------|------------------------|
| 1     | คลิกเพื่อกรอกข้อมูล... | คลิกเพื่อกรอกข้อมูล... |
| 2     | คลิกเพื่อกรอกข้อมูล... | คลิกเพื่อกรอกข้อมูล... |
| 3     | คลิกเพื่อกรอกข้อมูล... | คลิกเพื่อกรอกข้อมูล... |
| 4     | คลิกเพื่อกรอกข้อมูล... | คลิกเพื่อกรอกข้อมูล... |
| 5     | คลิกเพื่อกรอกข้อมูล... | คลิกเพื่อกรอกข้อมูล... |



## 1

## บทสรุปผู้บริหาร

## Executive Summary

รายงานฉบับนี้จัดทำขึ้นเพื่อนำเสนอผลการศึกษา ออกแบบ และติดตั้งระบบ \*\*ระบบทายผลกีฬา (Cloud Sports Prediction & Betting Platform - APEX PREDICT)\*\* ภายใต้สถาปัตยกรรม \*\*Secure 3-Tier Web Application บน Amazon Web Services (AWS)\*\* โดยมุ่งเน้นการปฏิบัติตามมาตรฐานความปลอดภัยระดับสากล ได้แก่ **AWS Well-Architected Framework (Security Pillar), CIS AWS Foundations Benchmark, และ OWASP Top 10**

ระบบถูกแบ่งแยกการทำงานออกเป็น 3 ระดับอย่างเด็ดขาดข้าม 2 Availability Zones (AZ-a และ AZ-b) ในภูมิภาคเอเชียตะวันออกเฉียงใต้ (Singapore - `ap-southeast-1`) ได้แก่: **1) Public Web Tier** (Nginx Reverse Proxy และ Application Load Balancer), **2) Private App Tier** (Node.js Betting & Prediction Engine ทำงานอยู่เบื้องหลัง NAT Gateway), และ **3) Isolated DB Tier** (Amazon RDS PostgreSQL Multi-AZ ซึ่งตัดขาดจากอินเทอร์เน็ตภายนอก 100%)

3

Tiers  
Web · App · DB

2

Availability Zones  
Multi-AZ (1a, 1b)

6

Subnets  
2 Pub · 2 Priv · 2  
Iso

3

Route Tables  
IGW · NAT · Local

5

Security Groups  
Chained Matrix

0

Open Port 22  
Zero Public SSH

## 2

## วัตถุประสงค์และความต้องการของระบบ

## Objectives &amp; Requirements

## 2.1 วัตถุประสงค์หลักของโครงการ (Project Objectives)

- การแบ่งแยกสิทธิ์และโซนเครือข่าย (Network Segmentation):** เพื่อป้องกันไม่ให้ผู้ไม่หวังดีสามารถเจาะเข้าถึงฐานข้อมูลที่มีความสำคัญสูงได้โดยตรง หากเกิดช่องโหว่ที่ชั้นเว็บเซิร์ฟเวอร์
- การปฏิบัติตามหลักสิทธิ์น้อยที่สุด (Principle of Least Privilege):** กำหนดสิทธิ์ของทั้งผู้ใช้งาน, เครื่องเซิร์ฟเวอร์ (IAM Instance Roles), และกลุ่มโพรไฟล์ (Security Groups) ให้มีสิทธิ์เท่าที่จำเป็นต้องใช้เท่านั้น
- การเข้าถึงเครื่องอย่างปลอดภัยโดยไม่เปิดพอร์ต 22 (Zero Public SSH via AWS SSM):** ยกเลิกการเปิดพอร์ต SSH สู่สาธารณะ และยกเลิกการใช้ Bastion Host เพื่อลดความเสี่ยงจากการถูกโจมตีแบบ Brute-Force
- การปกป้องข้อมูลและการเข้ารหัสทั้งระบบ (End-to-End Cryptography):** เข้ารหัสข้อมูลทั้ง In-Transit (TLS 1.3) และ At-Rest (AWS KMS AES-256) พร้อมบริหารความลับผ่าน AWS Secrets Manager
- ความพร้อมใช้งานสูงและการขยายตัวอัตโนมัติ (High Availability & Elasticity):** กระจายเวิร์กโหลดข้าม AZ และใช้ Auto Scaling Group เพื่อรองรับการขยายตัวในช่วงบิกแมตช์

## 2.2 ความต้องการด้านความปลอดภัย (Security Requirements)

| รหัส   | ข้อกำหนดด้านความปลอดภัย | แนวทางและกลไกที่นำมาแก้ปัญหา (Implementation)                                                                               |
|--------|-------------------------|-----------------------------------------------------------------------------------------------------------------------------|
| SEC-01 | Database Isolation      | ฐานข้อมูล RDS ถูกวางใน Isolated Subnet ที่ไม่มี Route <code>0.0.0.0/0</code> และกำหนด <code>Publicly Accessible = No</code> |
| SEC-02 | Traffic Inspection      | ติดตั้ง AWS WAF เชื่อมต่อหน้า Application Load Balancer บังคับใช้ Managed Rules (SQLi, XSS, Bad Inputs) และ Rate Limiting   |
| SEC-03 | In-Transit Encryption   | ALB บังคับใช้ SSL/TLS Certificate จาก AWS ACM พร้อม Redirect HTTP พอร์ต 80 สู่ HTTPS พอร์ต 443 ด้วยรหัส 301                 |

| รหัส   | ข้อกำหนดด้านความปลอดภัย         | แนวทางและกลไกที่นำมาแก้ปัญหา (Implementation)                                                                                     |
|--------|---------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| SEC-04 | At-Rest Encryption              | EBS Volumes และ RDS Database ถูกเข้ารหัสด้วย AWS KMS CMK (Key: <code>aws/rds</code> และ <code>aws/ebs</code> ) อัลกอริทึม AES-256 |
| SEC-05 | Zero Bastion SSH                | ไม่เปิดพอร์ต 22 ใน Security Group ใดๆ ผู้ดูแลระบบเข้าถึงเครื่องผ่าน AWS Systems Manager (SSM) Session Manager                     |
| SEC-06 | Data Integrity (Race Condition) | แอปพลิเคชันใช้ ACID Mutex Lock (จำลอง <code>SELECT ... FOR UPDATE</code> ) ป้องกัน Double Spending ขณะตัดแต้มทายผล                |

3

# หลักการแนวคิด และการดำเนินการตามแนวคิด

Design Principles vs  
Implementation

ในหัวข้อนี้จะอธิบายรายละเอียดว่าระบบยึดถือ **หลักการแนวคิด (Security & Architectural Concepts)** ใดบ้าง และทางกลุ่มได้ **ดำเนินการปฏิบัติจริงอย่างไรกับแนวคิดนั้น (How Implemented on AWS & App)** เพื่อให้เกิดความชัดเจนตามเกณฑ์ประเมินโครงการ:

1

การป้องกันความปลอดภัยเชิงลึก (Defense-in-Depth)

หลักการแนวคิด

ความปลอดภัยไม่สามารถพึ่งพาลูกป้องกันเพียงจุดเดียว (Single Layer of Defense) ได้ หากปรากฏการณ์ถูกเจาะหรือตั้งคำถามผิดพลาด ปรากฏการณ์ถัดไปต้องสามารถสกัดกั้นการโจมตีได้ทันที

การดำเนินการจริง

- Edge Tier:** กรองคำขอที่ AWS WAF (L7) และ AWS Shield Standard (L3/L4)
- Network Tier:** กรองด้วย Chained Security Groups และ Subnet NACLs
- Host Tier:** ติดตั้ง Nginx Reverse Proxy ซ่อน IP จริง และเปิดใช้งาน IMDSv2
- Application Tier:** ตรวจสอบ JWT Token, RBAC, และ Input Sanitization
- Data Tier:** RDS ใน Isolated Subnet เข้ารหัสด้วย AWS KMS

หลักฐานการตรวจสอบ: S07 Security Groups S15 ALB Listeners S16 WAF Web ACL

2

การให้สิทธิ์น้อยที่สุด (Principle of Least Privilege) & Zero Trust

หลักการแนวคิด

ทุก Entity (ผู้ใช้, เครื่องเซิร์ฟเวอร์, ฐานข้อมูล) จะได้รับสิทธิ์เท่าที่จำเป็นต่อการปฏิบัติหน้าที่เท่านั้น และ "ไม่เชื่อถือใครโดยปริยายแม้จะอยู่ในเครือข่ายเดียวกัน" (Zero Trust)

การดำเนินการจริง

- EC2 ใช้ **IAM Instance Profile** ที่เฉพาะเจาะจง `AmazonSSMManagedInstanceCore` และ `CloudWatchAgentServerPolicy`
- ไม่มีการฝัง AWS Access Key / Secret Key ในโค้ดหรือบน Server โดยเด็ดขาด
- Security Groups ยอมรับกราฟฟิคเฉพาะ **Security Group ID ของชั้นก่อนหน้า** (ไม่ระบุ IP กว้าง)
- ฐานข้อมูล `sg-db` รับเฉพาะ `sg-app` บนพอร์ต 5432 และ Deny Outbound 100%

หลักฐานการตรวจสอบ: S08 IAM Role S09 Secrets Manager S07 Security Groups

### 3 การยกเลิกการเปิดพอร์ต SSH สู่อารณะ (Zero Public SSH via AWS SSM)

#### หลักการแนวคิด

พอร์ต 22 (SSH) เป็นเป้าหมายอันดับหนึ่งของการโจมตีแบบ Brute-force และการสแกนหาช่องโหว่ การเปิด Bastion Host ทำให้เกิดจุดอ่อน (Single Point of Compromise) บน Public Subnet

#### การดำเนินการจริง

- ปิด TCP พอร์ต 22 ในทุก Security Group และไม่สร้าง EC2 Key Pair
- เชื่อมต่อบริหารจัดการเซิร์ฟเวอร์ผ่าน **AWS Systems Manager (SSM) Session Manager**
- การเข้าถึงยืนยันตัวตนผ่าน AWS IAM + Multi-Factor Authentication (MFA)
- คำสั่งที่พิมพ์ผ่านเทอร์มินัลทั้งหมดถูกบันทึกลงใน AWS CloudWatch Logs / S3 โดยไม่สามารถลบประวัติได้

หลักฐานการตรวจสอบ: **S01 Root MFA** **S07 Zero Port 22** **S20 SSM Session Manager**

### 4 การปกป้องข้อมูลและการเข้ารหัส (Data Protection In-Transit & At-Rest)

#### หลักการแนวคิด

ข้อมูลสำคัญ เช่น รหัสผ่าน, ข้อมูลกระเป๋าเงิน, สถิติการทายผล ต้องได้รับการคุ้มครองไม่ให้ถูกดักจับ (Sniffing) หรือถูกขโมยจากดิสก์ (Disk Theft) ได้

#### การดำเนินการจริง

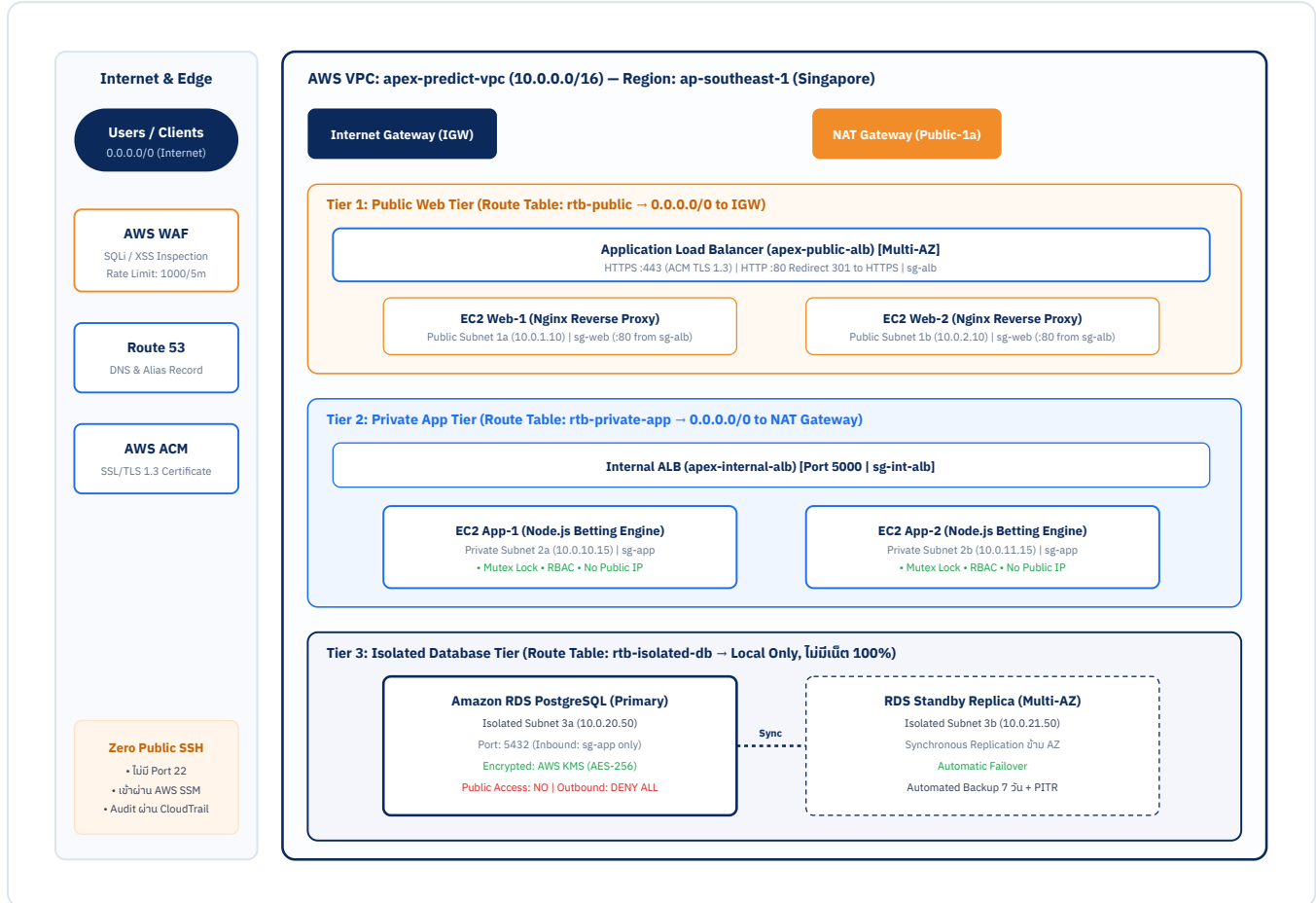
- In-Transit:** ใช้ TLS 1.3 ผ่าน AWS ACM ร่วมกับนโยบาย **ELBSecurityPolicy-TLS13-1-2-2021-06**
- At-Rest:** Amazon RDS และ EBS ถูกเข้ารหัสด้วย AWS KMS (AES-256)
- รหัสผ่าน Master Database และ JWT Secret ถูกเก็บและหมุนเวียนใน **AWS Secrets Manager**
- รหัสผ่านผู้ใช้ผ่านการ Hash ด้วยอัลกอริทึมที่ปลอดภัยก่อนจัดเก็บ

หลักฐานการตรวจสอบ: **S09 Secrets Manager** **S10 RDS Encryption** **S14 ACM Issued**

## 4 โครงสร้างสถาปัตยกรรมระบบ

### Architecture Structure

สถาปัตยกรรมของระบบทายผลกีฬา (APEX PREDICT) ได้รับการออกแบบให้เป็นไปตามหลักการ 3-Tier Multi-AZ บน Amazon Web Services (AWS) โดยแยกส่วนชั้นนำเสนอ, ชั้นตรรกะประมวลผล, และชั้นฐานข้อมูลออกจากกันอย่างชัดเจน:



รูปที่ 4.1: แผนผังสถาปัตยกรรมคลาวด์ Secure 3-Tier Web Application บน AWS (Multi-AZ) ระบบ APEX PREDICT

## 5 การออกแบบเครือข่าย และตาราง Routing Table

Network Design &amp; Routing

VPC ถูกออกแบบด้วย CIDR Block `10.0.0.0/16` และแบ่ง Subnets ออกเป็น 6 ตัว เพื่อรองรับสถาปัตยกรรม 3 ระดับกระจายข้าม 2 Availability Zones ได้แก่ `ap-southeast-1a` และ `ap-southeast-1b` โดยมีการจัดการเส้นทางการจราจรผ่านตาราง Routing Table 3 ชุดอย่างเป็นเอกเทศ:

### 5.1 รายละเอียดการแบ่ง Subnet (Subnetting Allocation Table)

| Subnet Name           | Tier ชั้นงาน | Availability Zone | IPv4 CIDR    | Public IP Auto-Assign | หน้าที่และความสำคัญ                    |
|-----------------------|--------------|-------------------|--------------|-----------------------|----------------------------------------|
| public-subnet-1a      | Public Web   | ap-southeast-1a   | 10.0.1.0/24  | Enabled (Yes)         | ALB Node 1, NAT Gateway, Web EC2-1     |
| public-subnet-1b      | Public Web   | ap-southeast-1b   | 10.0.2.0/24  | Enabled (Yes)         | ALB Node 2, Web EC2-2                  |
| private-app-subnet-2a | Private App  | ap-southeast-1a   | 10.0.10.0/24 | Disabled (No)         | App Engine Node 1 (Internal API :5000) |
| private-app-subnet-2b | Private App  | ap-southeast-1b   | 10.0.11.0/24 | Disabled (No)         | App Engine Node 2 (Internal API :5000) |
| isolated-db-subnet-3a | Isolated DB  | ap-southeast-1a   | 10.0.20.0/24 | Disabled (No)         | RDS PostgreSQL Primary (:5432)         |
| isolated-db-subnet-3b | Isolated DB  | ap-southeast-1b   | 10.0.21.0/24 | Disabled (No)         | RDS Standby Replica (Multi-AZ Sync)    |

### 5.2 ตารางเส้นทางเครือข่าย (Route Tables Configuration Matrix)

| Route Table Name                                 | Destination CIDR | Target Gateway                | Associated Subnets                                 | พฤติกรรมและการเชื่อมต่อและความปลอดภัย                                                                                                       |
|--------------------------------------------------|------------------|-------------------------------|----------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| <b>rtb-public</b><br>(Web Tier Route Table)      | 10.0.0.0/16      | local                         | • public-subnet-1a<br>• public-subnet-1b           | เชื่อมต่อกับ Internet Gateway เพื่อเปิดรับคำขอ HTTPS จากภายนอกสู่ ALB และส่งออกไปสู่ผู้ใช้                                                  |
|                                                  | 0.0.0.0/0        | Internet Gateway ( igw-xxxx ) |                                                    |                                                                                                                                             |
| <b>rtb-private-app</b><br>(App Tier Route Table) | 10.0.0.0/16      | local                         | • private-app-subnet-2a<br>• private-app-subnet-2b | <b>Egress-Only:</b> ออกอินเทอร์เน็ตได้ทางเดียวผ่าน NAT Gateway เพื่อถึงแอปพลิเคชัน หรือถึง Feed ผลบอลภายนอก <b>โลกภายนอกยังเข้ามาไม่ได้</b> |
|                                                  | 0.0.0.0/0        | NAT Gateway ( nat-xxxx )      |                                                    |                                                                                                                                             |

| Route Table Name                                      | Destination CIDR         | Target Gateway                                               | Associated Subnets                                                                                                            | พฤติกรรมกรรมการเชื่อมต่อและความปลอดภัย                                                                                  |
|-------------------------------------------------------|--------------------------|--------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| <code>rtb-isolated-db</code><br>(DB Tier Route Table) | <code>10.0.0.0/16</code> | <code>local</code><br>(ไม่มี <code>0.0.0.0/0</code> เด็ดขาด) | <ul style="list-style-type: none"><li><code>isolated-db-subnet-3a</code></li><li><code>isolated-db-subnet-3b</code></li></ul> | <b>Air-Gapped Isolation:</b> ตัดขาดจากโลกภายนอก 100% สื่อสารได้เฉพาะภายใน VPC ช่วยป้องกัน Data Exfiltration โดยสิ้นเชิง |

**⚠ ข้อมักำหนดความปลอดภัยสำคัญของ `rtb-isolated-db`:**

การไม่ระบุเส้นทาง `0.0.0.0/0` ไปยัง Internet Gateway หรือ NAT Gateway ในตาราง `rtb-isolated-db` เป็นหลักประกันทางกายภาพในระดับเครือข่าย (Network Hardening) ว่าฐานข้อมูลจะไม่มีทางติดต่อหรือถูกติดต่อจากอินเทอร์เน็ตภายนอกได้ แม้ว่าจะมีข้อผิดพลาดในการตั้งค่าระดับแอปพลิเคชันก็ตาม

6

Security Groups Matrix แบบลูกโซ่

Chained Security Groups

ระบบใช้หลักการ **Chained Security Groups** โดยไม่อนุญาตให้อ้างอิง IP CIDR แบบกว้างภายใน VPC แต่จะผูกสิทธิ์ Inbound เข้ากับ **Security Group ID ของชั้นงานก่อนหน้าโดยตรง** ทำให้เกิดการป้องกันแบบ Microsegmentation:

| Security Group | Tier ชั้นงาน       | Inbound Rule (Port)              | Source (ต้นทางที่อนุญาต)            | Outbound Rule                                    | เหตุผลด้านความปลอดภัย (Security Rationale)                   |
|----------------|--------------------|----------------------------------|-------------------------------------|--------------------------------------------------|--------------------------------------------------------------|
| sg-alb         | Public ALB         | TCP 443 (HTTPS)<br>TCP 80 (HTTP) | 0.0.0.0/0<br>(Internet)             | TCP 80 → sg-web                                  | เปิดรับทราฟฟิกจากผู้ใช้ทั่วไป โดยมี AWS WAF ช่วยสแกน Payload |
| sg-web         | Web Tier (Nginx)   | TCP 80 (HTTP)                    | sg-alb เท่านั้น<br>(ห้าม 0.0.0.0/0) | TCP 5000 → sg-int-alb<br>TCP 443 → Any (NAT/SSM) | ป้องกันไม่ให้บุคคลภายนอกบายพาส ALB ถึงตรงหา EC2 Nginx        |
| sg-int-alb     | Internal ALB       | TCP 5000 (Custom)                | sg-web เท่านั้น                     | TCP 5000 → sg-app                                | รับคำขอ Reverse Proxy จากเว็บเซิร์ฟเวอร์กระจายสู่ App Tier   |
| sg-app         | App Tier (Node.js) | TCP 5000 (Custom)                | sg-int-alb เท่านั้น                 | TCP 5432 → sg-db<br>TCP 443 → Any (NAT/Feed)     | App Engine ซ่อนตัวใน Private Subnet ตัดการเข้าถึงตรงจาก Web  |
| sg-db          | Database (RDS)     | TCP 5432 (PostgreSQL)            | sg-app เท่านั้น                     | Deny All (ลบออกทั้งหมด)                          | ฐานข้อมูลเปิดรับเฉพาะ App Engine และไม่ส่งทราฟฟิกออกภายนอก   |

| Security Group | Tier ชั้นงาน | Inbound Rule (Port)    | Source (ต้นทางที่อนุญาต) | Outbound Rule           | เหตุผลด้านความปลอดภัย (Security Rationale)                  |
|----------------|--------------|------------------------|--------------------------|-------------------------|-------------------------------------------------------------|
| Admin Access   | ทุก Tier     | เปิด TCP 22 (SSH) 100% | ไม่อนุญาตไอพีใดๆ         | HTTPS 443 ไปยัง AWS SSM | ตัดช่องโหว่ Brute-force 100% โดยใช้ AWS Systems Manager แทน |

## 7 โครงสร้างบทบาทผู้ใช้งาน (User Persona vs 3-Tier Access)

เพื่อจำลองหลักการ **Separation of Duties (SoD)** ระบบได้แบ่ง User Persona ออกเป็น 3 บทบาทหลักที่สอดคล้องกับชั้นสถาปัตยกรรมของ AWS:

| User Persona                           | บทบาทและหน้าที่ในระบบ                                             | สิทธิ์ Web Tier (Public) | สิทธิ์ App Tier (Private)          | สิทธิ์ DB Tier (Isolated)                 |
|----------------------------------------|-------------------------------------------------------------------|--------------------------|------------------------------------|-------------------------------------------|
| 1. ผู้ใช้ทั่วไป (player_alex)          | เข้าเล่นหน้าบ้าน ทายผลคู่ แข่งขัน ตรวจสอบแต้ม และประวัติโพย       | อนุญาต (HTTPS: 443)      | ห้ามเข้าถึงตรง (ผ่าน API เท่านั้น) | ตัดขาด 100% (ไม่มีสิทธิ์)                 |
| 2. ผู้ดูแลระบบปฏิบัติการ (ops_manager) | จัดการตารางแข่ง ปรับค่าน้ำ สรุปลผลการแข่งขัน แจกแต้ม ถึง Feed ออก | อนุญาต                   | อนุญาต (ผ่าน SSM & Internal API)   | ห้ามแก้ไขข้อมูลตรง (ผ่าน Engine เท่านั้น) |
| 3. ผู้ตรวจสอบความปลอดภัย (sec_auditor) | ตรวจสอบ Audit Logs, CloudTrail, Flow Logs, GuardDuty              | Read-Only Logs           | Read-Only Metrics                  | Read-Only Audit Trail                     |

8

การเฝ้าระวัง การสำรองข้อมูล และการกู้คืน

Monitoring & DR

8.1 การเฝ้าระวังและการบันทึก Log (Monitoring & Observability)

- **AWS CloudTrail** ( `apex-mgmt-trail` ): บันทึกทุก API Call ระดับ Management Plane เปิดใช้งาน Log File Integrity Validation เพื่อป้องกันการปลอมแปลงบันทึกประวัติ
- **Amazon GuardDuty**: ระบบตรวจจับภัยคุกคามอัจฉริยะ วิเคราะห์ VPC Flow Logs, DNS Logs และ CloudTrail Events เพื่อตรวจจับพฤติกรรมผิดปกติ เช่น การขุดคริปโต หรือ Reconnaissance
- **Amazon CloudWatch Alarms**: ตั้งตั้ง 4 Alarms สำคัญ ได้แก่: 1) CPU Utilization > 75% บน App ASG, 2) Unhealthy Host Count > 0 บน ALB, 3) HTTP 5XX Rate > 1% บน ALB, และ 4) Free Storage Space < 2 GB บน RDS ทั้งหมดส่งแจ้งเตือนผ่าน **Amazon SNS** ( `apex-security-alerts` ) ไปยังอีเมลทีมวิศวกร

8.2 แผนการสำรองข้อมูลและการกู้คืน (Backup & Disaster Recovery)

- **Amazon RDS Multi-AZ & Automated Backup**: ข้อมูลถูกทำสำเนาแบบ Synchronous ข้ามไปยัง Availability Zone สำรอง (AZ-b) แบบ Real-time พร้อมเปิดระบบ Automated Backup ย้อนหลัง 7 วัน รองรับ **Point-in-Time Recovery (PITR)** ระดับวินาที
- **EC2 Golden AMI Snapshot**: เครื่องเซิร์ฟเวอร์ที่ติดตั้งซอฟต์แวร์และ Hardening เสร็จสมบูรณ์ถูกจัดทำเป็น Golden AMI ( `apex-web-golden-ami-v1` ) เพื่อให้ Auto Scaling Group สามารถสับนั้เครื่องทดแทนได้ทันที

9

รายการหลักฐานภาพหน้าจอการติดตั้งจริง (Screenshots S01–S22)

หลักฐานการติดตั้งจริงบน AWS Management Console ที่จัดเก็บผ่านหน้าเว็บคู่มือ `frontend/deployment-guide.html` :

| รหัส | หัวข้อหลักฐานการติดตั้ง    | สิ่งที่ต้องเห็นในภาพหน้าจอเพื่อยืนยันความปลอดภัย                                                                             |
|------|----------------------------|------------------------------------------------------------------------------------------------------------------------------|
| S01  | Root Account MFA & Budgets | สถานะ MFA "Enabled" บน Root Account และหน้า AWS Budget Alert                                                                 |
| S02  | VPC Creation               | VPC <code>apex-predict-vpc</code> พร้อม IPv4 CIDR Block <code>10.0.0.0/16</code>                                             |
| S03  | Subnets Allocation         | Subnets 6 ตัว กระจาย 2 AZs (2 Public, 2 Private, 2 Isolated)                                                                 |
| S04  | Gateways Attachment        | Internet Gateway (Attached) และ NAT Gateway สถานะ Available พร้อม Elastic IP                                                 |
| S05  | Route Tables Configuration | Routes และ Subnet Associations ครบทั้ง 3 ตาราง (ยืนยัน DB ไม่มี 0.0.0.0/0)                                                   |
| S06  | VPC Flow Logs              | Flow Logs บน VPC ชี้ปลายทางเข้าสู่ CloudWatch Logs <code>/apex/vpc-flow-logs</code>                                          |
| S07  | Chained Security Groups    | Inbound Rules ของ <code>sg-alb</code> , <code>sg-web</code> , <code>sg-app</code> , <code>sg-db</code> (ยืนยันไม่มี Port 22) |
| S08  | IAM Instance Profile       | IAM Role <code>ApexEC2InstanceProfile</code> แบนนโยบาย SSM และ CloudWatch                                                    |

| รหัส | หัวข้อหลักฐานการติดตั้ง      | สิ่งที่ต้องเห็นในภาพหน้าจอเพื่อยืนยันความปลอดภัย                                     |
|------|------------------------------|--------------------------------------------------------------------------------------|
| S09  | Secrets Manager              | Secret <code>apex/prod/app</code> และ RDS Master Credentials ใน Secrets Manager      |
| S10  | RDS PostgreSQL Multi-AZ      | RDS สถานะ Multi-AZ, Encryption KMS (Enabled), Public access = No, <code>sg-db</code> |
| S11  | Internal ALB                 | Load Balancer <code>apex-internal-alb</code> (Scheme: Internal, Listener: 5000)      |
| S12  | App ASG & Target Group       | Instance 2 ตัวใน Private Subnets และสถานะ Healthy บน Target Group                    |
| S13  | Web ASG & Target Group       | Instance 2 ตัวใน Public Subnets และสถานะ Healthy บน Target Group                     |
| S14  | ACM SSL/TLS Certificate      | ใบรับรองสถานะ "Issued" รองรับ TLS 1.3                                                |
| S15  | Public ALB Listeners         | Listener HTTP: 80 Redirect 301 ไป HTTPS: 443 และกฎ TLS 1.3                           |
| S16  | AWS WAF Web ACL              | กฎ Managed Rules (Common, SQLi, Bad Inputs) และ Rate Limit ผูกกับ ALB                |
| S17  | Route 53 DNS Alias           | Record ชื่อ Alias ไปยัง DNS Name ของ <code>apex-public-alb</code>                    |
| S18  | CloudWatch & SNS Alarms      | Alarms สถานะ OK ผูกกับ SNS Topic <code>apex-security-alerts</code>                   |
| S19  | CloudTrail & GuardDuty       | CloudTrail Trail สถานะ Logging และ GuardDuty สถานะ Active                            |
| S20  | SSM Session Manager          | หน้าต่าง Terminal ของ EC2 App ผ่าน SSM (ยืนยันว่าไม่ต้องเปิดพอร์ต 22 SSH)            |
| S21  | End-to-End Application Test  | หน้าเว็บ HTTPS มีแม่กุญแจเขียว เข้าสู่ระบบ ทายผล และตัดแต้มได้สมบูรณ์                |
| S22  | Backup Snapshot & Golden AMI | Golden AMI ( <code>apex-web-golden-ami-v1</code> ) และ Manual RDS Snapshot           |